Организация отдела SoC (Security Operations Center)

Стартовая модель: команда L1 «под ключ» — 4 аналитика + руководитель группы. Режим работы: мониторинг и реагирование 24/7. Дата подготовки: 14.10.2026.

1. Состав команды и распределение ролей

При текущем штате функции инженера SOC и Threat Intelligence аналитика распределяются между L1 и руководителем. Ключевой принцип: **L1 работает по регламентам (playbook), руководитель отвечает за качество регламентов, обучение и внешнюю эскалацию.**

Роль	Кол-во / режим	Обязанности (стартовая модель)	Что НЕ входит
Руководитель группы SoC	1 ставка; 5/2 дневной + дежурный телефон по критичным инцидентам	Управление сменами и ротацией; ведение и актуализация playbooks; контроль качества триажа (выборочные ревью тикетов); обучение L1; метрики MTTD/MTTR и отчетность; настройка приоритетов алертов совместно с владельцами SIEM/EDR; связь с бизнес-заказчиками; управление дежурством в выходные.	Глубокая форензика, администрирование платформ (при отсутствии инженера — временная функция или подряд).
Аналитик L1 (триаж + дежурство)	4 ставки; график — по вариантам раздела 3	Первичный разбор алертов SIEM/EDR/NDR по playbook; обогащение данных (TI-фиды, WHOIS, внутренние IOC из EDR); типовые действия containment: блокировка IP/хоста/учетки по регламенту; заведение и ведение инцидентов в ITSM; передача смены по чек-листу; дежурство по выходным (ротация); часть времени — рутинная TI: проверка индикаторов, подписка на фиды, разметка кампаний по инструкции.	Reverse-инжиниринг, расследование сложных APT, разработка правил детектирования «с нуля», поддержка инфраструктуры SOC.

Внешний контур (обязателен при отсутствии L2/SOC-инженера): «экспертная сеть» — дежурные администраторы инфраструктуры/сети (контур блокировок и изоляции), выделенный представитель ИТ, договор с MSSP/консультантами на DFIR и сложные расследования. Критерии эскалации фиксируются в каждом playbook.

2. Исходные ограничения и как они влияют на графики

- **4 ставки L1 на покрытие 24/7** — это меньше классической нормы (8–10 человек). 168 ч/нед покрытия при штате 4 человека дают работу «впритык»: полноценных равных смен 3×2 человека не хватает.
- **Требование: без полных 24-часовых смен** — максимальная длина смены ограничена 8–12 часами.

• **Следствие:** либо часть суток закрывается сменами 12ч в составе 1 человека, либо в нерабочее время вводится режим on-call/вахты у части сотрудников, либо дежурство по выходным выносится в отдельную ротацию. Все три варианта даны ниже.

3. Варианты графиков 24/7 (4 × L1 + руководитель)

Вариант А. «Бригадный»: две смены по 12 часов, 2+2 (без ночного on-call)

Смена	Время	Состав	Покрытие
Дневная	08:00 – 20:00 (12 ч)	2 аналитика L1	Пн–Вс
Ночная	20:00 – 08:00 (12 ч)	2 аналитика L1	Пн–Вс

Каждый сотрудник работает 2/2 (два дня дневная, два дня ночная, четыре выходных) либо закрепляется за одной сменной парой с ротацией раз в месяц. Руководитель — 5/2, в выходные дежурный телефон по критичным инцидентам.

• **Плюсы:** непрерывное живое покрытие 24/7, минимум on-call, простая логика передачи смены, сотрудники видят полный цикл «день→ночь» (быстрее набирают опыт).

• **Минусы:** 12-часовые смены (в пределах требования, но утомляют); при болезни одного из пары на смене остается один человек; нагрузка ~180 ч/мес при 2/2 выше нормы — нужен фонд подмен (руководитель + оплачиваемые сверхурочные).

• **Риск и мера:** при одновременном отсутствии двоих покрытие падает. Меры: заранее оплачиваемые сверхурочные + право руководителя лично закрывать окно.

Вариант Б. «8/8 + on-call-ночь»: восьмичасовые смены в будни

Смена	Время	Состав	Покрытие
Утренняя	08:00 – 16:00	1 аналитик L1	Пн–Пт
Дневная	16:00 – 24:00	1 аналитик L1	Пн–Пт
Ночная (on-call)	24:00 – 08:00	Дежурный L1 (вахта 1 неделя из 4): удаленный отклик ≤ 15 мин, подключение/выезд по триггеру (критичный алерт)	Пн–Вс
Выходные	08:00 – 24:00	Вахта L1: два окна по 8 ч (дежурный + резервист)	Сб–Вс

• **Плюсы:** смены строго 8 часов (максимальное соответствие требованию «без длинных смен»); ночью не нужен человек «в кресле» — платим только за реальные вызовы; устойчивее к болезням в будни.

• **Минусы:** ночь и выходные — не «живой» мониторинг, а реакция по алерту: MTTD ночью растет; требуется надежная доставка алертов (выделенное устройство, авто-эскалация) и доплата за вахты/on-call (суммированный учет рабочего времени).

• **Кому подходит:** если ночной поток алертов мал и большинство инцидентов можно отложить до утра, кроме критичных (шифровальщик, компрометация AD, утечка данных).

Вариант В. Гибрид: плотный день + вечернее окно + недельная вахта

Окно	Время	Состав	Покрытие
Основное	07:00 – 17:00 (10 ч)	2 аналитика L1	Пн–Пт
Вечернее	17:00 – 01:00 (8 ч)	1 аналитик L1 (ротация из основного состава)	Пн–Пт
Ночь + выходные	01:00 – 07:00 и Сб–Вс	On-call-вахта 4-го сотрудника (недельная ротация), отклик ≤ 15 мин	Пн–Вс

• **Логика:** основной поток инцидентов — рабочие часы; плотный состав днем позволяет параллельно вести TI-рутину и тюнинг алертов. Дежурный по ночи/выходным меняется еженедельно.

• **Плюсы:** нет смен длиннее 10 часов; трое из четверых живут в нормальном ритме (лучше удержание); пиковая нагрузка закрыта двумя людьми.

• **Минусы:** самый сложный учет рабочего времени; роль «дежурного по выходным» должна быть добровольной и дополнительно оплачиваемой, иначе выгорание.

Сводное сравнение

Критерий	А: 12ч бригадный	Б: 8ч + on-call	В: гибрид 10ч
Макс. длина смены	12 ч	8 ч	10 ч
Живое покрытие ночью	Да	Нет (реакция)	Частично (on-call)
Устойчивость к больничным	Низкая	Средняя	Средняя
MTTD в нерабочее время	Минимальный	Зависит от отклика	Средний
Сложность учета раб. времени	Средняя	Высокая	Высокая
Риск выгорания	Высокий (ночные 12ч)	Средний	Низкий для ядра, высокий для вахты
Когда выбирать	Старт, поток алертов растет	Ночь тихая, бюджет ограничен	Компромисс ради людей

4. Обязательные процессы при любом графике

• **Playbooks (старт: 8–12 штук):** фишинг, вредонос на хосте (EDR), подозрительная активность УЗ, аномальный сетевой трафик/C2, DLP-инцидент, доступ к admin-интерфейсам, шифровальщик (критический), компрометация почты/BEC, сканирование/DDoS, эксплуатация уязвимости в периметре, общий шаблон триажа.

• **Чек-лист передачи смены:** открытые инциденты, ожидаемые изменения на инфраструктуре, дежурные контакты эскалации, ложные срабатывания дня. Отметка обеих сторон в журнале.

• **Матрица эскалации:** уровень 1 — L1 по playbook; уровень 2 — руководитель группы; уровень 3 — внешние эксперты/MSSP + владелец актива. Таймбокс: критичный инцидент — уведомление руководителя ≤ 15 мин.

• **Метрики:** MTTD, MTTR, доля эскалаций L1 → внешний контур, процент ложных срабатываний, соблюдение SLA по типам инцидентов, число инцидентов вне рабочее

время (ключ к выбору графика).

• **Обучение L1 (TI-компетенции):** еженедельный часовой практикум: разбор реального инцидента недели, работа с TI-фидами (abuse.ch, OTX, внутренние IOC), базовый threat hunting по шаблонам MITRE ATT&CK.

5. Дорожная карта развития

Этап	Срок	Содержание
Стабилизация	1–2 мес.	Выбор графика (по факту ночного потока алертов), первые 10 playbooks, регламент передачи смены, подключение TI-фидов к SIEM, договор с внешним контуром DFIR.
Автоматизация	3–6 мес.	SOAR/скрипты на типовые действия (блокировка IOC, изоляция хоста, сбор улик), дашборд метрик, тюнинг правил с вендором SIEM, найм 5-й ставки L1 для снятия напряжения с графика.
Многоуровневость	6–12 мес.	Выделение L2-аналитика (расследования, hunt), SOC-инженера (платформы), TI-аналитика; переход к модели L1/L2/L3; пересмотр графика на классический по мере роста штата.

Примечание: варианты графиков приведены как проектные; перед внедрением согласовать с отделом труда и кадров (суммированный учет рабочего времени, оплата сверхурочных и ночных — ст. 96, 152, 154 ТК РФ). Рекомендуемый первый шаг — собрать статистику алертов за 2–4 недели, затем выбирать между вариантами А и Б.